SEMANA 15 · PARTE 1

Hacking ético: método, permiso y evidencia

Parte 1 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 15 · Periodo 2026-2 · Barranquilla, Colombia

Qué es y qué no es el hacking ético

No es atacar mejor: es atacar con permiso, con método y con evidencia que sirva para corregir.

Tres condiciones que lo separan de un delito



PERMISO

autorización escrita

del dueño del sistema



MÉTODO

fases documentadas

y reproducibles



EVIDENCIA

hallazgos verificables

y un informe útil



RESULTADO

el sistema queda

mejor que antes

Sin la primera condición, las otras dos no valen nada.

Fuente: NIST SP 800-115 (2008); Ley 1273 de 2009

El ciclo de una prueba, según NIST

Planificar, descubrir, atacar y analizar: cuatro fases con entregables en cada una.

Fases de la prueba según NIST SP 800-115



1 · PLANIFICACIÓN

alcance, reglas y autorización

2 · DESCUBRIMIENTO

inventario de activos y servicios

3 · ATAQUE

verificación controlada de hallazgos

4 · POSTERIOR

análisis, informe y remediación

El informe no es un anexo del final: es un entregable de cada fase.

Fuente: NIST SP 800-115, Technical Guide to Information Security Testing

Reglas de enfrentamiento: el contrato técnico

Qué se prueba, desde dónde, en qué horario y qué está prohibido tocar, por escrito y firmado.

Lo que debe quedar escrito antes de empezar

QUÉ SE PRUEBA

dominios, rangos de IP
y aplicaciones concretas

DESDE DÓNDE

origen de las pruebas
y credenciales si aplica

EN QUÉ HORARIO

ventana acordada
y contacto de emergencia

QUÉ NO SE TOCA

sistemas críticos, datos
reales y terceros

CÓMO SE REPORTA

canal, formato y
plazos de entrega

SI ALGO FALLA

protocolo de parada
y escalamiento

Si algo no está escrito, no está autorizado.

Fuente: NIST SP 800-115; OWASP (seguridad de aplicaciones web) WSTG (planificación)

La autorización escrita, pieza por pieza

Quién firma, sobre qué activos, con qué vigencia y con qué límite de responsabilidad.

Qué debe contener el documento

QUIÉN AUTORIZA
nombre, cargo y facultad
para autorizar

SOBRE QUÉ
lista de activos
y direcciones exactas

VIGENCIA
fecha de inicio
y de fin

LÍMITES
lo que queda excluido
de forma explícita

RESPONSABILIDAD
manejo de datos
y confidencialidad

FIRMA
del dueño y del
responsable técnico

Una autorización genérica no protege a nadie: tiene que nombrar los activos.

Fuente: Ley 1273 de 2009; NIST SP 800-115; ISO/IEC 27001

Producción, réplica o laboratorio

Cada ambiente da distinta fidelidad y distinto riesgo; la elección se justifica, no se improvisa.

Tres ambientes y su costo

PRODUCCIÓN

máxima fidelidad

riesgo real de afectar

RÉPLICA

casi igual al real

requiere mantenimiento

LABORATORIO

riesgo cero

menos fidelidad

EN PRODUCCIÓN

solo lectura

y ventana corta

EN RÉPLICA

datos anonimizados

y aviso al negocio

EN TODOS

el riesgo se acuerda

con el dueño

El ambiente se elige por el riesgo aceptable, no por comodidad.

Fuente: NIST SP 800-115; OWASP WSTG

Caja negra, gris y blanca

Cuánta información se entrega al equipo cambia el tiempo, el costo y el realismo de la prueba.

Tres enfoques según la información inicial



CAJA NEGRA

sin información previa

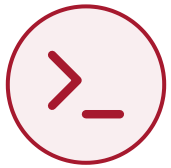
como un atacante externo



CAJA GRIS

algo de contexto:

cuentas y arquitectura



CAJA BLANCA

código y diseño

a la vista del equipo



EFECTO

más información,

menos tiempo y costo

Ninguno es mejor: el enfoque se elige según la pregunta que se quiera responder.

Fuente: NIST SP 800-115; OWASP WSTG

Reconocimiento pasivo: lo que ya es público

Dominios, correos, tecnologías y personas: información abierta que no toca el sistema del otro.

Fuentes abiertas y qué revelan

DOMINIOS

registros públicos

y fechas de creación

DNS

subdominios y

servicios expuestos

CORREOS

nombres y cargos

del personal

TECNOLOGÍAS

qué usa el sitio

según lo que publica

DOCUMENTOS

PDF y metadatos

publicados por error

REDES SOCIALES

rutinas y contactos

de los empleados

Es pasivo porque no envía tráfico al objetivo: lee lo que ya está publicado.

Fuente: MITRE (matrices ATT&CK y ATLAS) ATT&CK, táctica TA0043 (Reconnaissance)

Reconocimiento activo: ya hay contacto

Consultas y sondeos que llegan al sistema del otro: aquí empieza a hacer falta la autorización.

Del dato público al paquete enviado



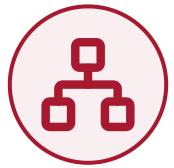
CONSULTAS DNS

preguntas al servidor del dominio



SONDEO DE HOSTS

qué direcciones responden



PUERTOS

qué servicios están abiertos



VERSIONES

qué software y qué versión

Cada paso agrega información y también responsabilidad: aquí ya se necesita permiso.

Fuente: NIST SP 800-115 (descubrimiento); MITRE ATT&CK TA0043

Analizar no es explotar

Un escáner señala candidatos; confirmar el fallo y medir su impacto es trabajo del analista.

Escáner contra analista

EL ESCÁNER

compara versiones
con bases públicas

EL ANALISTA

confirma si el fallo
es real y explotable

FALSOS POSITIVOS

versión parcheada
o servicio engañoso

FALSOS NEGATIVOS

fallo real que
el escáner no ve

PRIORIDAD

impacto en el negocio,
no solo la puntuación

ENTREGA

candidatos verificados,
nunca la salida cruda

El escáner produce candidatos; el analista produce hallazgos.

Fuente: NVD (nvd.nist.gov); FIRST CVSS; OWASP Top 10

CVSS: leer una puntuación con criterio

Vector de ataque, complejidad, privilegios e impacto: la puntuación es una suma de decisiones.

Qué mide la puntuación base

VECTOR

desde la red

o local

COMPLEJIDAD

condiciones especiales

para explotar

PRIVILEGIOS

qué se necesita

tener antes

INTERACCIÓN

si requiere

una víctima

CONFIDENCIALIDAD

qué datos

se exponen

INTEGRIDAD

qué se puede

alterar

La puntuación describe el fallo; el riesgo describe la organización.

Fuente: FIRST — Common Vulnerability Scoring System (first.org/cvss)

El informe: el entregable que sí importa

Hallazgo, evidencia, severidad, impacto y remediación: sin esos cinco, no hay informe.

Anatomía de un hallazgo

TÍTULO

qué falla, en una frase entendible

EVIDENCIA

captura, registro o reproducción

SEVERIDAD

puntuación y justificación

IMPACTO

qué podría pasar en el negocio

REMEDIACIÓN

cómo corregirlo, paso a paso

ESTADO

abierto, en revisión o corregido

Un hallazgo sin evidencia reproducible es una opinión.

Fuente: NIST SP 800-115; OWASP WSTG (reporte)

PRIORIDAD

Priorizar: riesgo, no puntuación

Un fallo crítico en un servidor de pruebas pesa menos que uno medio en el sistema de pagos.

De la lista al plan de trabajo



La lista sin prioridad es ruido; la prioridad sin contexto es arbitraria.

Fuente: OWASP Top 10; NIST SP 800-53 Rev. 5

La línea que no se cruza

Autorización, proporcionalidad y confidencialidad: tres reglas que valen también fuera del trabajo.

Tres reglas del oficio



AUTORIZACIÓN

lo que no está escrito

no está permitido



PROPORCIONALIDAD

lo mínimo necesario

para demostrar el fallo



CONFIDENCIALIDAD

lo hallado no se

divulga ni se reutiliza

Un hallazgo bien intencionado, sin permiso, sigue siendo un delito.

Fuente: Ley 1273 de 2009; NIST SP 800-115

Síntesis de la Parte 1

Permiso, método y evidencia: la prueba se sostiene en el proceso, no en la herramienta.

Lo que quedó definido



Con el marco claro, la parte 2 entra al reconocimiento y al análisis en un entorno aislado.

Fuente: NIST SP 800-115; OWASP WSTG; Ley 1273 de 2009

SEMANA 15 · PARTE 2

Reconocer y analizar sin tocar lo ajeno

Parte 2 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 15 · Periodo 2026-2 · Barranquilla, Colombia

ENTORNO

El laboratorio 8 y el entorno aislado

Próximamente: máquinas propias, redes internas y sin salida a internet durante las pruebas.

Condiciones de un entorno aislado



MÁQUINAS PROPIAS

el objetivo es un sistema que tú controlas



RED INTERNA

sin exposición hacia fuera



SIN INTERNET

nada que pueda alcanzar a un tercero



SNAPSHOT

volver al estado inicial en un paso



DATOS FICTICIOS

nada de información de personas reales



REGISTRO

todo lo hecho queda documentado



GLOSARIO

aislado no significa inofensivo: significa contenido

En un entorno aislado puedes equivocarte sin consecuencias para nadie más.

Fuente: NIST SP 800-115 (ambiente de prueba); guía del Lab 8 (próximamente)

Reconocer un dominio desde fuera

Registro, fechas, servidores de nombres y contactos: lo que el propio dueño publicó.

Qué dice el registro público de un dominio

TITULAR
quién lo registró
y desde cuándo

SERVIDORES DNS
dónde se resuelve
el dominio

FECHAS
creación y última
renovación

ESTADO
activo, en gracia
o bloqueado

CONTACTOS
datos públicos
de administración

PRIVACIDAD
qué se ocultó
a propósito

Todo esto es público por diseño: leerlo no requiere autorización.

Fuente: registros públicos de dominio; MITRE ATT&CK TA0043

El sistema de nombres como fuente de verdad

Subdominios, registros de correo y servicios: el DNS suele revelar más de lo que se publica.

Qué se puede aprender del DNS

SUBDOMINIOS

servicios internos

expuestos sin querer

CORREO

qué proveedor

se usa

TEXTOS

políticas de correo

y de dominio

ALIAS

nombres alternos

del mismo servicio

DELEGACIÓN

quién administra

cada zona

HISTÓRICO

qué existía

y ya no

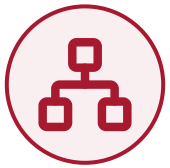
Un subdominio olvidado es una puerta que nadie está mirando.

Fuente: MITRE ATT&CK TA0043; documentación de DNS

Inventariar hosts: quién responde

Antes de mirar servicios hay que saber qué direcciones existen y cuáles están activas.

Del rango al inventario



RANGO

el alcance autorizado

define las direcciones



SONDEO

qué direcciones

responden



INVENTARIO

lista de hosts

activos



CONTRASTE

comparar con el

inventario oficial

La diferencia entre lo que responde y lo que el dueño cree tener ya es un hallazgo.

Fuente: NIST SP 800-115 (descubrimiento de activos)

Puertos y servicios: qué hay escuchando

Un puerto abierto es una puerta; un servicio antiguo en ese puerto es una puerta sin cerradura.

De puerto a servicio



PUERTO ABIERTO

algo está escuchando

SERVICIO

qué programa responde

VERSIÓN

qué tan viejo es ese programa

EXPOSICIÓN

quién puede llegar a él

Un puerto abierto es una puerta; un servicio antiguo es una puerta sin cerradura.

Fuente: NIST SP 800-115; NVD (vulnerabilidades por versión)

Identificar la versión sin equivocarse

Los servicios mienten: un banner puede estar modificado o ser de un proxy intermedio.

Por qué el banner no es prueba

BANNER
lo que el servicio
dice ser

MODIFICADO
el administrador
puede cambiarlo

INTERMEDIO
un proxy responde
por otro

COMPROBACIÓN
contrastar con
el comportamiento

CONSECUENCIA
una versión mal leída
invalida el hallazgo

REGLA
si no se confirma,
se reporta como probable

Un hallazgo que depende de una versión mal leída se cae en la revisión.

Fuente: NVD; OWASP WSTG (identificación de tecnologías)

De la versión al fallo conocido

CVE identifica el fallo, NVD lo describe y CVSS lo puntúa: tres piezas distintas que se leen juntas.

Tres fuentes que se complementan



CVE

identificador único del fallo

NVD

descripción y productos afectados

CVSS

puntuación de severidad

CONTEXTO

¿aplica a tu configuración?

Que exista un CVE para tu versión no significa que tu sistema sea explotable.

Fuente: NVD (nvd.nist.gov); FIRST CVSS

Verificar un hallazgo sin explotarlo

Demostrar la exposición con el mínimo necesario: una prueba controlada y reversible.

El mínimo necesario para demostrar

OBSERVAR
qué responde
sin modificarlo

CONFIRMAR
que el fallo
está presente

DEMOSTRAR
el impacto mínimo
suficiente

DETENERSE
no ir más allá
de lo acordado

REVERTIR
dejar el sistema
como estaba

EVIDENCIA
captura y
marca de tiempo

La proporcionalidad no es una formalidad: es lo que mantiene la prueba legal.

Fuente: NIST SP 800-115; Ley 1273 de 2009

Guardar evidencia que sirva

Fecha, origen, destino, resultado y reproduce: sin esos cinco datos, la captura no prueba nada.

Qué debe acompañar a cada captura

FECHA Y HORA
con zona horaria
y sincronizada

ORIGEN
desde qué equipo
se hizo

DESTINO
sobre qué activo
exacto

RESULTADO
qué se obtuvo,
literal

CÓMO REPETIR
los pasos, en orden

QUÉ NO SE TOCÓ
lo que quedó
fuera de alcance

Una captura sin contexto no se puede defender en una revisión.

Fuente: NIST SP 800-115; OWASP WSTG (reporte)

Documentar el alcance antes de la primera consulta

Escribir qué se va a hacer y qué no, y firmarlo, incluso en un laboratorio de clase.

El hábito que se entrena desde el laboratorio

QUÉ VOY A HACER
lista de acciones previstas

SOBRE QUÉ
máquinas y direcciones

HASTA DÓNDE
el límite que no se cruza

CÓMO LO REGISTRO
dónde queda la evidencia

CUÁNDO PARO
señal de detención

QUIÉN RESPONDE
a quién aviso si algo sale mal

El hábito se forma en el laboratorio, donde equivocarse es barato.

Fuente: NIST SP 800-115; Ley 1273 de 2009

Dos informes en uno

El técnico dice qué falla y cómo se corrige; el ejecutivo dice qué riesgo implica y qué decisión pide.

El mismo hallazgo, dos lecturas

A QUIÉN
técnico que corrige
y directivo que decide

QUÉ DICE
detalle reproducible
frente a impacto

LONGITUD
anexo completo
frente a dos páginas

LENGUAJE
términos exactos
frente a analogías

QUÉ PIDE
un cambio concreto
frente a una decisión

ERROR TÍPICO
entregar solo uno
de los dos

El mismo hallazgo se cuenta dos veces y ninguna es opcional.

Fuente: NIST SP 800-115; OWASP WSTG (reporte)

ERRORES

Cinco errores que arruinan una prueba

Salirse del alcance, no documentar, confiar en el escáner, exagerar y no revertir los cambios.

Los tropiezos más frecuentes

SALIRSE DEL ALCANCE

probar algo que
nadie autorizó

NO DOCUMENTAR

perder la evidencia
en el camino

CONFIAR EN EL ESCÁNER

entregar la salida
sin verificar

EXAGERAR

inflar la severidad
para impresionar

NO REVERTIR

dejar cambios
en el sistema

NO AVISAR

enterarse el dueño
por un tercero

Cualquiera de los cinco basta para que la prueba no sirva, aunque el trabajo técnico sea bueno.

Fuente: NIST SP 800-115; Ley 1273 de 2009

Síntesis de la Parte 2

Reconocer desde lo público, inventariar con permiso, verificar sin explotar y documentar todo.

El método completo de campo



OBSERVAR

lo público

sin tocar

INVENTARIAR

hosts y servicios

con permiso

VERIFICAR

el fallo, con el

mínimo necesario

DOCUMENTAR

evidencia y

alcance

Con el método claro, la parte 3 mira lo mismo desde la defensa.

Fuente: NIST SP 800-115; MITRE ATT&CK; NVD

LÍMITE

Cuándo parar el reconocimiento

El permiso define hasta dónde llegar; el sentido común define cuándo detenerse antes.

Tres señales para detenerse

FUERA DE ALCANCE

una dirección que no está en la lista

SISTEMA CRÍTICO

algo que el dueño marcó como intocable

DATOS REALES

información de personas

SÍNTOMA

el servicio empieza a fallar

DUDA

no sabes si está permitido

REGLA

si dudas, paras y preguntas

Ante la duda, se detiene y se consulta: nunca se sigue para ver qué pasa.

Fuente: NIST SP 800-115; Ley 1273 de 2009

SEMANA 15 · PARTE 3

Ver como atacante, cerrar como defensor

Parte 3 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 15 · Periodo 2026-2 · Barranquilla, Colombia

El reconocimiento visto desde la defensa

Lo que el atacante encuentra es exactamente lo que tú publicaste sin darte cuenta.

El mismo dato, dos lecturas

PARA EL ATACANTE

un punto de entrada
y una ruta

PARA EL DEFENSOR

una exposición que
hay que cerrar

BANNER

tecnología y versión
visibles

SUBDOMINIO

servicio olvidado
fuera de inventario

REGISTRO DNS

contacto antiguo
y servidores viejos

REGLA

si no lo necesitas
expuesto, ciérralo

Todo lo que el atacante encuentra, en algún momento alguien lo publicó.

Fuente: MITRE ATT&CK TA0043; NIST SP 800-53 Rev. 5

Superficie de ataque: lo que está expuesto

Cada servicio publicado, cada puerto abierto y cada dato en internet suma superficie.

Componentes de la superficie

SERVICIOS

los que escuchan hacia fuera

PUERTOS

abiertos y sin necesidad

APLICACIONES

versiones antiguas y paneles

DATOS

documentos con metadatos

PERSONAS

correos y cargos públicos

TERCEROS

proveedores con acceso

La superficie no se mide en servidores, se mide en puntos de entrada.

Fuente: NIST SP 800-53 Rev. 5; OWASP Top 10

Reducción de superficie: apagar lo que sobra

El control más barato y más efectivo: si un servicio no se necesita, se apaga o se restringe.

Cuatro decisiones que reducen superficie

APAGAR
servicios y puertos sin uso

RESTRINGIR
acceso solo desde las redes necesarias

AUTENTICAR
nada de paneles abiertos

MINIMIZAR
sin datos ni metadatos innecesarios

VERSIONAR
retirar lo que ya no tiene soporte

REVISAR
calendario de revisión periódica

Lo que no existe no se puede vulnerar: es el control más barato del inventario.

Fuente: NIST SP 800-53 Rev. 5; OWASP Top 10

Segmentar: que un fallo no sea total

Separar redes y limitar el movimiento lateral convierte un incidente en un problema acotado.

De un fallo aislado a un incidente total



La segmentación no evita el fallo: evita que el fallo se convierta en catástrofe.

Fuente: NIST SP 800-53 Rev. 5; material S14 (SASE y zero trust)

Parches: la ventana de exposición

El riesgo no es tener un fallo conocido, es cuánto tiempo pasa hasta que se corrige.

El tiempo es la variable



SE PUBLICA

el fallo se hace público



SE DETECTA

tu inventario lo confirma



SE CORRIGE

se aplica el parche



VENTANA

tiempo expuesto al riesgo

Un fallo conocido y sin corregir es una decisión, no un accidente.

Fuente: NVD; NIST SP 800-53 Rev. 5 (gestión de parches)

Detectar el reconocimiento

Un escaneo deja rastro: muchas conexiones cortas, errores repetidos y consultas de DNS inusuales.

Señales de que alguien está mirando

MUCHAS CONEXIONES
a puertos distintos
en poco tiempo

ERRORES
respuestas de rechazo
repetidas

DNS
consultas a nombres
que no existen

PATRÓN
un origen recorriendo
un rango

HORARIO
actividad fuera de
lo habitual

CORRELACIÓN
varias señales
del mismo origen

El reconocimiento casi nunca es silencioso: se ve en los registros si alguien los mira.

Fuente: MITRE ATT&CK TA0043; NIST SP 800-61 Rev. 3

Señuelos: hacer visible lo invisible

Un servicio falso y bien vigilado avisa cuando alguien lo toca, sin riesgo para el sistema real.

Lo que aporta un señuelo

QUÉ ES
un servicio falso
que nadie debe usar

PARA QUÉ
detectar contacto
no autorizado

VENTAJA
cero falsos positivos
por definición

RIESGO
mal configurado
se vuelve una puerta

REGLA
no guarda datos
reales

APOYO
complementa, no
reemplaza la detección

Un señuelo bien puesto no se equivoca: si alguien lo toca, es porque no debía.

Fuente: NIST SP 800-53 Rev. 5; NIST SP 800-61 Rev. 3

Registrar y correlacionar

Un registro aislado es un dato; varios registros con la misma hora son una historia.

Del dato suelto a la historia



REGISTRO

qué pasó, cuándo

y desde dónde

RETENCIÓN

cuánto tiempo

se conserva

CORRELACIÓN

varias fuentes

con la misma hora

ALERTA

una hipótesis

verificable

Sin hora sincronizada, la correlación es imposible: es el requisito más olvidado.

Fuente: NIST SP 800-61 Rev. 3; NIST SP 800-53 Rev. 5 (auditoría)

Endurecer lo que sí está expuesto

Contraseñas robustas, MFA (autenticación multifactor), mínimo privilegio y actualizaciones: lo básico sigue siendo lo decisivo.

Los cuatro controles que más reducen riesgo

MFA
en todo acceso
remoto y administrativo

MÍNIMO PRIVILEGIO
cada cuenta con
lo justo

ACTUALIZACIÓN
con calendario
y responsable

CONFIGURACIÓN
sin valores
de fábrica

CIFRADO
en tránsito
y en reposo

MONITOREO
saber si algo
cambió

Lo básico bien hecho cubre más riesgo que cualquier herramienta avanzada.

Fuente: NIST SP 800-53 Rev. 5; OWASP Top 10; NIST SP 800-61 Rev. 3

La prueba como control periódico

Una prueba aislada es una foto; un programa de pruebas es una película del riesgo que cambia.

De la foto a la película

FRECUENCIA
al menos una vez al año, y tras cambios

ALCANCE
rotar sistemas críticos

REGRESIÓN
repetir lo que ya se corrigió

MÉTRICA
cuántos hallazgos se cierran

DUEÑO
quién responde por el cierre

REGISTRO
histórico para auditoría

Una prueba sin seguimiento de cierre es un gasto, no un control.

Fuente: ISO/IEC 27001; NIST SP 800-53 Rev. 5

Métricas que sí sirven para reportar

Tiempo de exposición, tiempo de corrección y porcentaje de cierre: tres números que la dirección entiende.

Tres números y su lectura

TIEMPO DE EXPOSICIÓN

desde el hallazgo

hasta el cierre

TIEMPO DE CORRECCIÓN

desde la asignación

hasta el arreglo

% DE CIERRE

hallazgos cerrados

sobre el total

COBERTURA

activos probados

sobre el inventario

REINCIDENCIA

fallos que vuelven

a aparecer

TENDENCIA

mejora o empeora

en el tiempo

Un número sin tendencia no dice nada; la comparación con el trimestre anterior sí.

Fuente: ISO/IEC 27001; NIST SP 800-53 Rev. 5; NIST SP 800-61 Rev. 3

Divulgación responsable y programas de recompensas

Alguien encontró un fallo en tu sistema: el problema no es que lo sepa, es cómo se entera del resto.

Del hallazgo a la corrección, sin ruido



HALLAZGO

alguien encuentra un fallo

AVISO PRIVADO

canal claro y plazo de respuesta

CORRECCIÓN

se arregla y se verifica

PUBLICACIÓN

acordada y, si aplica, reconocida

Un canal de reporte conocido convierte un ataque potencial en una mejora.

Fuente: OWASP (divulgación); NIST SP 800-61 Rev. 3; Ley 1273 de 2009

Síntesis de la Parte 3

Cerrar superficie, segmentar, parchear y observar: la defensa es aburrida y por eso funciona.

Cuatro decisiones defensivas



CERRAR

apagar y restringir lo que sobra

SEGMENTAR

contener el daño si algo falla

PARCHEAR

reducir la ventana de exposición

OBSERVAR

detectar el reconocimiento

La defensa es aburrida y por eso funciona: constancia, no heroísmo.

Fuente: NIST SP 800-53 Rev. 5; ISO/IEC 27001; MITRE ATT&CK

Si la prueba encuentra algo grave

Un hallazgo crítico no espera al informe: se avisa de inmediato por el canal acordado.

Del hallazgo crítico a la acción



DETECTAR

un fallo explotable

en ese momento

AVISAR

canal de emergencia

de inmediato

CONTENER

aplicar el control

mínimo

DOCUMENTAR

qué se hizo

y cuándo

El informe puede esperar; una exposición activa no.

Fuente: NIST SP 800-61 Rev. 3; NIST SP 800-115

SEMANA 15 · PARTE 4

El marco legal y el cierre de la semana

Parte 4 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 15 · Periodo 2026-2 · Barranquilla, Colombia

Ley 1273 de 2009: las conductas tipificadas

Acceso abusivo, interceptación, daño informático y software malicioso: cuatro conductas que aplican a pruebas.

Cuatro conductas del código penal

ACCESO ABUSIVO
entrar a un sistema
sin autorización

INTERCEPTACIÓN
capturar datos
en tránsito ajeno

DAÑO INFORMÁTICO
alterar, borrar
o inutilizar

SOFTWARE MALICIOSO
usar programas
para dañar

SUPLANTACIÓN
usar identidad
ajena en línea

AGRAVANTES
la ley contempla
circunstancias

La ley no pregunta por la intención: pregunta si había autorización.

Fuente: Ley 1273 de 2009 (Colombia), arts. 269A a 269J

Datos personales: la otra ley que aplica

En una prueba encontrarás información de personas: tratarla exige autorización, confidencialidad y minimización.

Qué obliga a hacer con los datos encontrados

AUTORIZACIÓN
de los titulares o base legal

FINALIDAD
solo para lo autorizado

MINIMIZACIÓN
lo mínimo necesario

SEGURIDAD
proteger lo encontrado

CONFIDENCIALIDAD
no divulgar ni reutilizar

DESTRUCCIÓN
al terminar, eliminar

Un hallazgo con datos de personas no se puede usar como ejemplo en una diapositiva.

Fuente: Ley 1581 de 2012 (Colombia); Ley 1273 de 2009

Dónde está exactamente la frontera

Alcance escrito, activos nombrados, ventana acordada y proporcionalidad: las cuatro condiciones del permiso.

Cuándo una prueba es legítima

ALCANCE ESCRITO
activos nombrados
y firmados

VENTANA
fechas y horas
acordadas

PROPORCIÓN
lo mínimo para
demostrar

CONTENCIÓN
revertir lo que
se cambió

SILENCIO
no divulgar
lo hallado

EVIDENCIA
registrar y
conservar

Sin las dos primeras, las otras cuatro no se pueden ni demostrar.

Fuente: Ley 1273 de 2009; NIST SP 800-115

El acuerdo de confidencialidad

Lo que ves en una prueba no se comenta, no se reutiliza y no se guarda más de lo necesario.

Tres compromisos del trabajo

NO COMENTAR

ni en charlas

ni en clase

NO REUTILIZAR

para otra prueba

sin permiso

NO ACUMULAR

borrar al

terminar

PLAZO

cuánto tiempo

se conserva

EXCEPCIÓN

reporte legal

obligatorio

SOPORTE

el informe es el

único entregable

La confidencialidad no es cortesía: es una condición del contrato y de la ley.

Fuente: Ley 1581 de 2012; NIST SP 800-115; ISO/IEC 27001

CONSECUENCIAS

Qué pasa cuando falta el permiso

La consecuencia no es solo jurídica: se pierde el caso, la evidencia y la credibilidad profesional.

Un error con tres costos

JURÍDICO

la conducta está tipificada

PROBATORIO

la evidencia queda contaminada

REPUTACIONAL

el cliente no vuelve a confiar

LABORAL

responsabilidad del profesional

ECONÓMICO

indemnizaciones y sanciones

COLATERAL

el sistema queda peor

Un hallazgo obtenido sin permiso no se puede usar ni para defender el sistema.

Fuente: Ley 1273 de 2009; Ley 1581 de 2012

Certificaciones, roles y carrera

El oficio tiene roles definidos: analista, pentester, respuesta a incidentes y arquitectura de seguridad.

Roles y su foco

ANALISTA SOC (centro de operaciones de seguridad)

detectar y clasificar

todos los días

PENTESTER

probar y reportar

por encargo

RESPUESTA

contener e investigar

incidentes

ARQUITECTO

diseñar para que

el fallo no escale

GRC

política, riesgo

y cumplimiento

FORMACIÓN

certificaciones y

práctica continua

El rol define qué se puede hacer sin permiso: el pentester no actúa sin alcance.

Fuente: NIST NICE Framework; ENISA (ciberseguridad y formación)

Glosario de la semana

Alcance, reglas de enfrentamiento, OSINT, CVE, CVSS y hallazgo: el vocabulario de la semana.

Los términos que hay que manejar

ALCANCE

qué se prueba y qué no

RoE

reglas de enfrentamiento

OSINT

información de fuentes abiertas

CVE

identificador de un fallo

CVSS

puntuación de severidad

HALLAZGO

fallo con evidencia

Si puedes usar estos términos en una frase propia, el tema está entendido.

Fuente: NIST SP 800-115; NVD; FIRST CVSS; OWASP

REPASO

Repaso de la Unidad 3 hasta aquí

Del entorno Linux a la denegación de servicio y la IA (inteligencia artificial): el camino que llevamos en la unidad.

El recorrido de la unidad hasta hoy



Fuente: plan de la Unidad 3 del curso

El Laboratorio 8, próximamente

Se publica con su guía: reconocimiento y análisis de vulnerabilidades en un entorno aislado y propio.

Lo que va a pedir el laboratorio

ENTORNO
máquinas propias
y red interna

ALCANCE
una página escrita
antes de empezar

RECONOCIMIENTO
dominio, DNS
y hosts

ANÁLISIS
servicios, versiones
y fallos conocidos

EVIDENCIA
capturas con
contexto

INFORME
técnico y
ejecutivo

Sin fecha ni pasos todavía: la guía se publica con el laboratorio, no antes.

Fuente: guía del Laboratorio 8 (próximamente)

Lo que viene: la semana 16

Agentes de inteligencia artificial en la seguridad: clasificación de alertas con verificación humana y repaso.

El cierre de la unidad

AGENTES
que clasifican
alertas

TRIAGE
priorizar sin
perder el juicio

VERIFICACIÓN
siempre un humano
decide

RIESGO
el agente también
se puede engañar

REPASO
toda la unidad
en una sesión

CIERRE
qué sigue en
la siguiente unidad

Un agente acelera la clasificación; la decisión de responder sigue siendo humana.

Fuente: material de la semana 16; plan de la Unidad 3

Dónde seguir leyendo

NIST SP 800-115, OWASP WSTG, MITRE ATT&CK, NVD, FIRST CVSS y la Ley 1273 de 2009.

Las fuentes de la semana

NIST SP 800-115
guía de pruebas
de seguridad

OWASP WSTG
catálogo de pruebas
de aplicaciones

MITRE ATT&CK
tácticas y
técnicas

NVD
vulnerabilidades
y CVE

FIRST CVSS
sistema de
puntuación

LEY 1273
delitos informáticos
en Colombia

Documentación primaria: en este campo los blogs envejecen muy rápido.

Fuente: compilación de fuentes de la semana 15

Cierre de la semana 15

Permiso, proporción y evidencia: lo que separa a un profesional de alguien que sabe usar herramientas.

Las tres frases de la semana



PERMISO

lo que no está escrito

no está permitido



PROPORCIÓN

lo mínimo para

demostrar el fallo



EVIDENCIA

sin registro no hay

informe que valga

La habilidad técnica se aprende en meses; el criterio se aprende toda la vida.

Fuente: NIST SP 800-115; Ley 1273 de 2009; OWASP

CHECKLIST

Checklist de una prueba autorizada

Ocho puntos que se revisan antes de empezar y antes de entregar: si falta uno, no se firma.

Lo que se verifica antes y después

1 · ALCANCE
activos y ventana
por escrito

2 · FIRMA
de quien puede
autorizar

3 · CONTACTO
de emergencia
disponible

4 · ENTORNO
propio o
autorizado

5 · EVIDENCIA
capturas con
contexto

6 · REVERSIÓN
sistema como
estaba

7 · INFORME
técnico y
ejecutivo

8 · ENTREGA
canal acordado
y confidencial

Un checklist no reemplaza el criterio: lo hace verificable.

Fuente: NIST SP 800-115; Ley 1273 de 2009; ISO/IEC 27001

Preguntas frecuentes de la semana

¿Necesito certificación para trabajar en esto? ¿Puedo practicar en casa? ¿Qué hago si encuentro un fallo?

Tres dudas que siempre aparecen



¿CERTIFICACIÓN?

ayuda a entrar,

no reemplaza criterio



¿PRACTICAR EN CASA?

sí, en tus propias

máquinas



¿Y SI ENCUENTRO UN FALLO?

avisar por el canal

y no divulgarlo



¿PUEDO USAR UN ESCÁNER?

solo dentro del

alcance



¿Y SI NO HAY CANAL?

buscar el contacto

formal del sitio



¿ES DELITO PRACTICAR?

no, si el sistema

es tuyo

Practicar en tus máquinas es legítimo; practicar en las de otro no.

Fuente: Ley 1273 de 2009; OWASP; NIST SP 800-115